



Aqsa Khalid
Lecturer
School of Computing

CS3002 Information Security

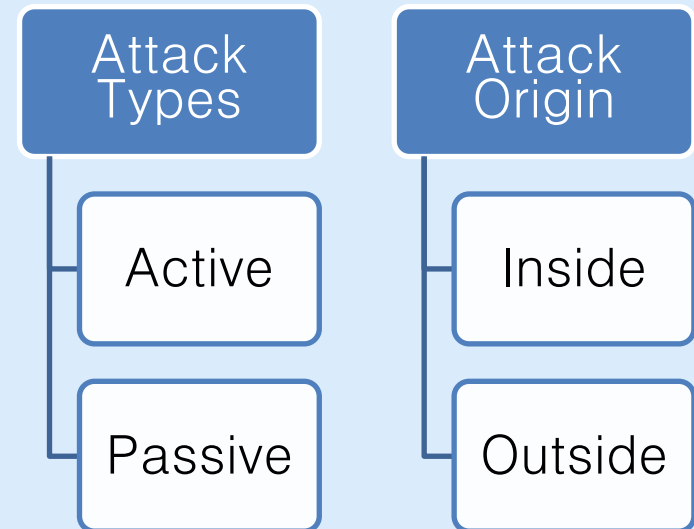


Threats and Attacks

Attack Classification



- In passive attacks, the adversary is not interacting with system entities (e.g. only packet sniffing)
- Inside attacks are carried out by an adversary within the organization.



Attack Vectors and Surfaces



- The **path or method an attacker uses to exploit a weakness** is called **attack vector** .
- Vectors define different ways for attackers to get in.
- Example attack vectors
 - Email attachments which can contain malicious code
 - USB drives, because they may contain malicious software that runs when plugged in
 - Weak credentials, which can be guessed by attackers
 - Server misconfiguration, that allow attackers to steal sensitive data

Attack Vectors and Surfaces



- **Attack surface** is the **set of all vulnerable points**, assets, and pathways where an attacker can try to enter a system.
- The more exposed services, interfaces, and users, the larger the attack surface and the more opportunities an attacker has.
- **Reducing the attack surface makes systems harder to compromise**. Disabling unused services, limiting access, and educating users all help shrink the number of possible entry points.
 - Physical security example: For a castle, each door, window and secret passage are possible attack vectors. Set of all those vectors is castle's attack surface.

Examples of Attacks/Threats



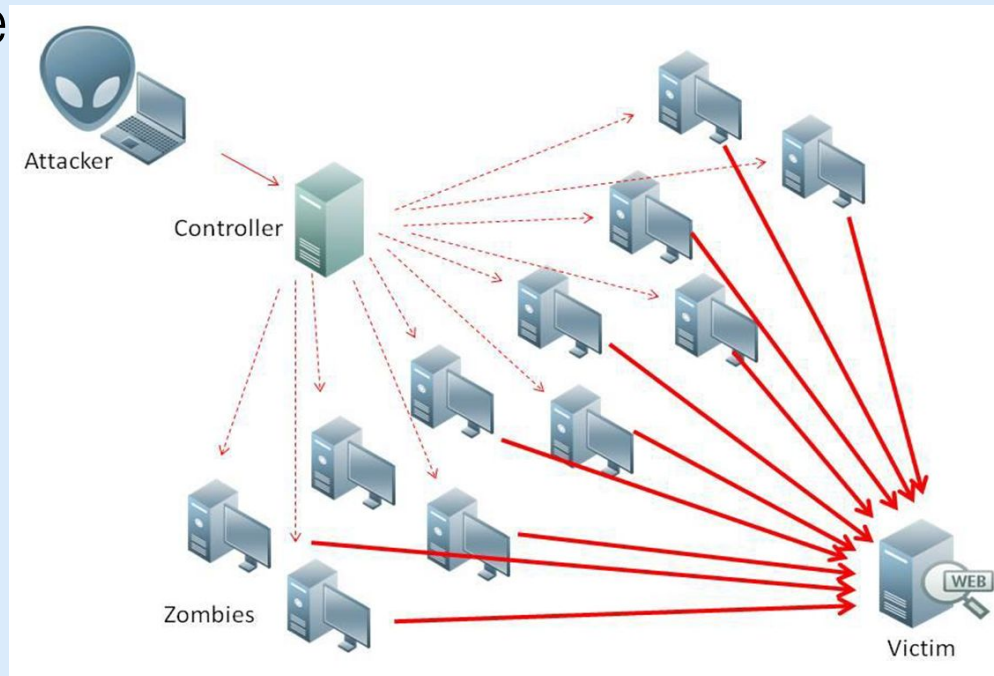
Malware: malicious software

- Virus
 - Spreads quickly
 - Attached to a host file (exe, document)
- Worms
 - Do not require a host file
 - Can self-replicate and self-propagate over local network
- Trojans
 - Disguised as an essential or useful software

Examples of Attacks/Threats



- Bots: Used to launch Distributed Denial-of-Service (DDoS) attacks
 - Hundreds or thousands of devices are compromised (zombies) and remotely activated by attacker



Examples of Attacks/Threats



Password attacks

- Cracking: guess or reverse-calculate a password from its hashcode
- Cracking techniques:
 - Brute force: Application of computing and network resources to try every possible combination of characters of a password
 - Dictionary: Uses a list of commonly used passwords (the dictionary) as guesses

Examples of Attacks/Threats



Brute force password cracking time estimate

Case-Sensitive Passwords Using a Standard Alphabet Set (with Numbers and 20 Special Characters)		
Password Length	Odds of Cracking: 1 in (Based on Number of Characters ^ Password Length):	Estimated Time to Crack*
8	2,044,140,858,654,980	2.7 hours
9	167,619,550,409,708,000	9.4 days
10	13,744,803,133,596,100,000	2.1 years
11	1,127,073,856,954,880,000,000	172.5 years
12	92,420,056,270,299,900,000,000	14,141.9 years
13	7,578,444,614,164,590,000,000,000	1,159,633.8 years
14	621,432,458,361,496,000,000,000,000	95,089,967.6 years
15	50,957,461,585,642,700,000,000,000,000	7,797,377,343.5 years
16	4,178,511,850,022,700,000,000,000,000,000	639,384,942,170.1 years

Examples of Attacks/Threats



- Money extortion by blackmail
 - after data theft
 - after data hostage: **ransomware**
- Vandalism
 - e.g. defacing public websites
 - Destroy image of the business

Examples of Attacks/Threats



Network based attacks

- Packet Sniffing
 - Monitor data traveling over the network
- IP Spoofing
 - Modify the sender address in IP header
- Man-in-the-middle (MITM) attacks
 - Hijacking the session to delete or forge the data in transit

Examples of Attacks/Threats



Human error or failure

- Carelessness of employees
- Shoulder surfing
- Social engineering
 - using social skills to convince people to reveal confidential information
 - psychological pressure
 - showing acquaintance with company's procedures and habits
 - **Phishing** : Sending spoofed but genuine-looking messages to targets

Examples of Attacks/Threats



Hacking

- Attacker first deeply examines the target system
- Bypasses security controls using skills and/or fraud
- After a successful attack, next step is **privilege escalation**
 - The higher the privilege, the more the possible harm

Examples of Attacks/Threats



- Expert hackers
 - Develop software scripts and program exploits
 - Will often create attack software and share with others
- Novice hackers
 - Use existing software to exploit a system
 - Also known as **script kiddies**
 - Do not usually fully understand the systems they hack

Examples of Attacks/Threats



Copyright Infringement

- Piracy of books, software, multimedia

Large scale attacks

- Cyberterrorism
 - Attacks affecting widespread users
- Cyberwarfare
 - State-sponsored attacks against rival states

Examples of Attacks/Threats



Threats of unforeseen circumstances

- Internet service issues
 - Outage (downtime) or degradation
- Power blackouts and faults
- Forces of nature
 - Natural disasters
 - Require planning in advance. Organizations should create
 - business continuity plan
 - disaster recovery plan

Attacks and Consequences



Consequence	Attack
Unauthorized Disclosure	Exposure: Sensitive data are directly released to an unauthorized entity. Interception: An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. Inference: A threat action whereby an unauthorized entity indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from characteristics or by-products of communications. Intrusion: An unauthorized entity gains access to sensitive data by circumventing a system's security protections.

Attacks and Consequences



Consequence	Attack
Deception An authorized entity receiving false data and believing it to be true.	Masquerade: An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity. Falsification: False data deceive an authorized entity. Repudiation: An entity deceives another by falsely denying responsibility for an act.

Attacks and Consequences



Consequence	Attack
Disruption.	Incapacitation: Prevents or interrupts system operation by disabling a system component. Corruption: Undesirably alters system operation by adversely modifying system functions or data. Obstruction: A threat action that interrupts delivery of system services by hindering system operation.
Usurpation An unauthorized entity taking control of system services or functions	Misappropriation: An entity assumes unauthorized logical or physical control of a system resource. Misuse: Causes a system component to perform a function or service that is detrimental to system security.

Causes of Insufficient Security



- Networks are insecure: by default (most) communications are made in clear
- LANs operate in broadcast
- Geographical connections are not made through end-to-end dedicated lines but:
 - through shared lines
 - through third-party routers
 - weak user authentication (normally password-based)
- Software is not sufficiently tested, bugs and weaknesses remain

Causes of Insufficient Security



Weakest link in the chain: **Human beings**

- Low problem understanding (lack of awareness)
- Make mistakes when overloaded, stressed etc.
- Natural tendency to trust
- Complex interfaces/architectures can annoy or mislead the user and originate erroneous behaviors
- Naive users are an easy target (e.g. “change your password immediately with the following one, because your PC is under attack”) ...
- ...but experienced users are targeted too

Causes of Insufficient Security



- Defensive strategies are reactionary.
- Thousands — perhaps millions — of system with weak security are connected to the Internet.
- Increasingly complex software is being written by programmers who have no training in **writing secure code**.
- Attacks and attack tools transcend geography and national boundaries.
- The difficulty of criminal investigation of cybercrime coupled with the complexity of international law means that prosecution of computer crime is unlikely.